UTA MACS — Community Operating System (COS)

Enterprise Architecture & Design Document v2.0

> **This document supersedes `ARCHITECTURE.md` v1.** Key improvements: mandatory API gateway, service abstraction layer, 6-role model, 19 modules, feature flag system, DPDPA 2023 + GST + TDS compliance, RLS security fixes, PII encryption, rate limiting, MFA, append-only audit, full Azure migration plan.

PART 0 — SECURITY, PRIVACY & COMPLIANCE GAPS IN v1

A thorough review of `ARCHITECTURE.md` v1 identified the following issues that this document resolves.

Critical Security Gaps Found

#	Gap	Risk
1	**No API Gateway** — frontend calls Supabase SDK directly	Any migration = full rewrite
2	**No rate limiting** on login, password reset, OTP	Brute force / credential stuffing
3	**No CSRF protection** on POST endpoints	Cross-site request forgery
4	**No server-side input sanitization** — NoticeEditor.tsx rich text	XSS injection into notices
5	**RLS `complaints_update` missing `WITH CHECK`**	Attacker can overwrite `raised_by`
6	**Cached counters (`vote_count`, `like_count`)**	Concurrent writes cause integer drift
7	**Audit log mutability** — no append-only RLS	Admin can delete audit evidence
8	**No MFA** for Admin or Executive	Account takeover = full system compromise
9	**No session timeout policy** — JWT expiry undefined	Stolen tokens valid indefinitely
10	**No security headers** — CSP, HSTS, X-Frame-Options absent	XSS, clickjacking, MITM
11	**Storage public paths in DB**	Direct file access without authorization

Privacy Gaps Found

#	Gap	Impact
1	**PII in plaintext** — phone, flat number, IP addresses	Data breach exposes raw personal data

#	Gap	Impact
2	**No data retention policy**	Audit logs / notifications accumulate indefinitely
3	**No right-to-erasure endpoint**	DPDPA 2023 non-compliance
4	**Profile photos accessible to all auth users**	Not scoped to owner
5	**Anonymous poll gap** — NULL user_id traceable via timing	Privacy guarantee is false
6	**No consent management**	Cannot prove informed consent under DPDPA

Compliance Gaps Found (India-Specific)

#	Gap	Regulation
1	No explicit consent tracking, no data localization	**DPDPA 2023**
2	Raw IP stored = PII; no documented security practices	**IT Act 2000 / CERT-In Rules**
3	SMS/WhatsApp planned without DLT registration	**TRAI DLT**
4	No GST invoice generation for paid services	**GST Act**
5	No TDS tracking on vendor payments	**IT Act Sec 194C**
6	AGM records, financials have no formal workflow	**TS MACS Act 1995**
7	Payments table allows UPDATE/DELETE	**Cooperative audit standards**

Architectural Migration Risks

#	Risk	Consequence
1	Supabase SDK directly imported in every UI component	Migration = full frontend rewrite
2	No `/api/v1/` versioned endpoints	Breaking changes affect all clients
3	Business logic locked in Edge Functions	Won't migrate to Azure Functions automatically
4	No feature flags	Enable/disable modules requires code deployment
5	No service layer	Zero abstraction between UI and DB

PART 1 — DESIGN PRINCIPLES

1. **Process-driven, not feature-driven** — every module models a real-world workflow with explicit state machines

2. **API-first** — all data access via versioned REST `/api/v1/*`; zero direct DB access from UI
3. **Service abstraction** — `AuthService`, not `supabase.auth`; swap provider with one env var change
4. **Migration-ready** — Supabase → Azure without touching a single line of frontend code
5. **Modular & configurable** — feature toggles at global/module/sub-module/role level via admin UI
6. **Zero-trust security** — authenticate at API layer AND data layer (defense in depth)
7. **Privacy by design** — minimize PII, encrypt sensitive fields, enforce data retention
8. **Compliance by default** — DPDPA 2023, IT Act 2000, TS MACS Act 1995, GST, TDS built in
9. **Audit everything** — append-only audit trail; no soft delete without trace
10. **Multi-tenant ready** — `society_id` FK on every tenant table from day one

---

PART 2 — ARCHITECTURE OVERVIEW

```
┌──────────────────────────────────────────────────────────────────────┐
│                              PUBLIC INTERNET                         │
└──────────────────────────────────────────────────────────────────────┘
              │                                  │
          utamacs.org                     portal.utamacs.org
              │                                  │
   ┌──────────▼──────────┐          ┌──────────▼──────────────────┐
   │   GitHub Pages      │          │   Vercel (Astro SSR)        │
   │   Static HTML       │          │   React Islands (client:load)│
   │   10 public pages   │          │   Protected /portal/* routes │
   └─────────────────────┘          └──────────────────────────────┘
                                                │ HTTPS only
                                   ┌────────────▼──────────────────────┐
                                   │          API GATEWAY LAYER        │
                                   │   /api/v1/auth       /api/v1/members │
                                   │   /api/v1/complaints /api/v1/events  │
                                   │   /api/v1/finance    /api/v1/notices │
                                   │   /api/v1/facilities /api/v1/vendors │
                                   │   /api/v1/visitors   /api/v1/admin   │
                                   │                                     │
                                   │   Middleware stack (every request):  │
                                   │   RateLimiter → JWT → Role →        │
                                   │   FeatureFlag → Handler → AuditLog  │
                                   └────────────────────────────────────┘
                                                │
                                   ┌────────────▼──────────────────────┐
                                   │           SERVICE LAYER           │
                                   │  AuthService       MemberService  │
                                   │  ComplaintService  FinanceService │
                                   │  NotificationService StorageService │
                                   │  FacilityService   VisitorService │
                                   │  FeatureFlagService PermissionService │
                                   │  (provider-agnostic interfaces only) │
                                   └────────────────────────────────────┘
                                                │ config.PROVIDER switch
                                   ┌────────────▼──────────────────────┐
                                   │      PROVIDER IMPLEMENTATIONS     │
```

```
│   ┌──────────────┐   ┌──────────────┐   │
│   │  Supabase    │   │ Azure (future)│   │
│   │  Auth        │   │ Entra Ext. ID │   │
│   │  PostgreSQL  │   │ Azure PgSQL   │   │
│   │  Storage     │   │ Blob Storage  │   │
│   │  Realtime    │   │ SignalR Svc   │   │
│   │  Edge Funcs  │   │ Azure Funcs   │   │
│   └──────────────┘   └──────────────┘   │
└──────────────────────────────────────────┘
```

Key principle: Frontend never imports Supabase SDK directly. All calls go to `/api/v1/*`. Provider swap = set `PROVIDER=azure` in environment + deploy Azure provider implementations. Zero frontend changes required.

PART 3 — ROLE MODEL (6 ROLES)

Role	Description
`public`	Unauthenticated visitor to utamacs.org
`member`	Verified flat owner or registered tenant
`executive`	Elected committee member
`admin`	Super admin — full system access
`security_guard`	Gate duty staff — visitor/delivery management only
`vendor`	External service provider — assigned work orders only

Role-Permission-Feature Matrix

Feature / Module	public	member	exec	admin	guard	vendor
View public pages	✓	✓	✓	✓	✓	✓
Login / manage profile	—	✓	✓	✓	✓	✓
MEMBERS						
View own profile	—	✓	✓	✓	—	—
View member directory	—	✓	✓	✓	—	—
Manage all members + roles	—	—	—	✓	—	—
COMPLAINTS						
Raise complaint	—	✓	✓	✓	—	—
View own complaints	—	✓	✓	✓	—	—
View all complaints	—	—	✓	✓	—	—

Feature / Module	public	member	exec	admin	guard	vendor
Assign / update status	—	—	✓	✓	—	—
Internal (exec-only) comments	—	—	✓	✓	—	—
NOTICES						
View published notices	✓	✓	✓	✓	—	—
Create / publish notices	—	—	✓	✓	—	—
EVENTS						
View events	✓	✓	✓	✓	—	—
Register / RSVP	—	✓	✓	✓	—	—
Create / manage events	—	—	✓	✓	—	—
POLLS						
Vote in polls	—	✓	✓	✓	—	—
Create polls	—	—	✓	✓	—	—
View full results	—	partial	✓	✓	—	—
FINANCE						
View own dues	—	✓	✓	✓	—	—
Manage all dues	—	—	✓	✓	—	—
Financial reports / P&L	—	—	✓	✓	—	—
GST invoices / TDS reports	—	—	✓	✓	—	—
FACILITIES						
Book facility	—	✓	✓	✓	—	—
Manage facilities / slots	—	—	✓	✓	—	—
VISITORS						
Pre-approve visitor	—	✓	✓	✓	—	—
Log entry / exit	—	—	—	✓	✓	—
View visitor logs	—	own only	✓	✓	✓	—
VENDORS						
View assigned work orders	—	—	—	—	—	✓
Manage vendors / work orders	—	—	✓	✓	—	—
COMMUNITY						
View / react to posts	—	✓	✓	✓	—	—

Feature / Module	public	member	exec	admin	guard	vendor
Create posts	—	✓	✓	✓	—	—
Moderate / pin posts	—	—	✓	✓	—	—
ADMIN						
Feature flags config	—	—	—	✓	—	—
Audit log viewer	—	—	—	✓	—	—
System settings	—	—	—	✓	—	—
Data erasure (DPDPA)	—	—	—	✓	—	—

PART 4 — FEATURE FLAG SYSTEM

Schema

```
feature_flags (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid REFERENCES societies(id),
  module_key      text NOT NULL,    -- 'complaints', 'finance',
'visitor_mgmt'
  feature_key     text NOT NULL,    -- 'complaint_attachments',
'paid_events'
  is_enabled      boolean DEFAULT true,
  allowed_roles   text[],           -- NULL = all auth roles; e.g.
['admin','executive']
  config_json     jsonb,            -- {"max_file_size_mb": 5,
"sla_enabled": true}
  updated_by      uuid,
  updated_at      timestamptz DEFAULT now(),
  UNIQUE(society_id, module_key, feature_key)
)

module_configurations (
  id              uuid PK,
  society_id      uuid,
  module_key      text UNIQUE,
  display_name    text,
  is_active       boolean DEFAULT true,
  display_order   int,
  icon            text,
  updated_at      timestamptz
)
```

Feature Key Taxonomy

```
Module                Feature Keys
──────────────────    ──────────────────────────────────────────────────────
complaints            attachments, internal_comments, sla_tracking,
auto_assignment, escalation
finance               billing_engine, payment_gateway, gst_invoicing,
tds_tracking, dues_reminders
events                paid_events, qr_attendance, waitlist, feedback_form
polls                 anonymous_voting, result_export, multiple_choice,
one_vote_per_unit
visitor_mgmt          pre_approval_qr, pre_approval_otp, delivery_tracking,
staff_attendance
facility_booking      slot_booking, paid_booking, deposit_management,
cancellation_policy
community             posts, marketplace, classifieds, skill_directory
notifications         email, sms_trai_dlt, whatsapp_trai_dlt, push, realtime
documents             version_control, access_control,
digital_acknowledgement
asset_mgmt            amc_alerts, maintenance_schedule
```

Runtime Enforcement (3 Layers)

- **API layer**: `FeatureFlagService.guard(module, feature, role)` checked in middleware before every handler
- **UI layer**: `useFeatureFlag(moduleKey, featureKey)` React hook — hides/shows components dynamically
- **Cache**: flags cached in memory with 60-second TTL to minimize per-request DB roundtrips

Admin Configuration UI

```
System Settings → Feature Configuration
┌──────────────────────────────────────────────────────────────────────┐
│ ▼ MODULE: Complaints              [● Enabled]   [Roles: All]         │
│   ├─ Attachments                  [● Enabled]   Max: 10MB  [Edit]    │
│   ├─ SLA Tracking                 [● Enabled]   Config     [Edit]    │
│   ├─ Auto Assignment              [○ Disabled]  Config     [Edit]    │
│   └─ Internal Comments            [● Enabled]   Exec+ only           │
│                                                                      │
│ ▼ MODULE: Visitor Management      [○ Disabled]  [Enable All]         │
│   ├─ Pre-Approval (QR/OTP)        [○ Disabled]  Config     [Edit]    │
│   └─ Delivery Tracking            [○ Disabled]  Config     [Edit]    │
│                                                                      │
│ ▼ MODULE: Finance                 [● Enabled]   [Roles: Exec+]       │
│   ├─ GST Invoicing                [● Enabled]   GSTIN:     [Edit]    │
│   ├─ TDS Tracking                 [○ Disabled]  Enable for vendors   │
│   └─ Payment Gateway              [○ Disabled]  Integrate  [Edit]    │
└──────────────────────────────────────────────────────────────────────┘
```

PART 5 — API GATEWAY DESIGN

Route Reference

```
Base: /api/v1/

Auth:
  POST   /api/v1/auth/login
  POST   /api/v1/auth/logout
  POST   /api/v1/auth/refresh
  POST   /api/v1/auth/forgot-password
  POST   /api/v1/auth/reset-password
  POST   /api/v1/auth/mfa/enable
  POST   /api/v1/auth/mfa/verify

Members:
  GET    /api/v1/members
  GET    /api/v1/members/:id
  PUT    /api/v1/members/:id
  DELETE /api/v1/members/:id/personal-data    (DPDPA right to erasure)
  POST   /api/v1/members/:id/roles

Complaints:
  GET    /api/v1/complaints
  POST   /api/v1/complaints
  GET    /api/v1/complaints/:id
  PUT    /api/v1/complaints/:id/status
  POST   /api/v1/complaints/:id/assign
  POST   /api/v1/complaints/:id/comments
  POST   /api/v1/complaints/:id/attachments
  GET    /api/v1/complaints/:id/history

Finance:
  GET    /api/v1/finance/dues
  GET    /api/v1/finance/dues/:id
  POST   /api/v1/finance/dues/:id/payments
  GET    /api/v1/finance/payments/:id/receipt
  GET    /api/v1/finance/reports/summary
  GET    /api/v1/finance/reports/tds
  POST   /api/v1/finance/invoices/generate

Visitors:
  GET    /api/v1/visitors/pre-approvals
  POST   /api/v1/visitors/pre-approvals
  PUT    /api/v1/visitors/pre-approvals/:id/cancel
  POST   /api/v1/visitors/entry
  PUT    /api/v1/visitors/logs/:id/exit
  GET    /api/v1/visitors/logs

Facilities:
  GET    /api/v1/facilities
  GET    /api/v1/facilities/:id/availability
```

```
    POST   /api/v1/facilities/:id/bookings
    PUT    /api/v1/facilities/bookings/:id/cancel

  Admin:
    GET    /api/v1/admin/audit-logs
    GET    /api/v1/admin/feature-flags
    PUT    /api/v1/admin/feature-flags/:id
    GET    /api/v1/admin/system-health
```

Middleware Stack (executes on every request, in order)

```
1. Rate Limiter        100 req/min general; 10 login attempts/15min per IP
2. Security Headers    CSP, HSTS, X-Frame-Options, X-Content-Type-Options
(see below)
3. JWT Validator       AuthService.validateToken() — provider-agnostic
interface
4. Role Extractor      attach req.user.role, req.user.id,
req.user.societyId to context
5. Feature Flag Guard  FeatureFlagService.guard(module, feature, role) —
403 if disabled
6. Permission Check    PermissionService.authorize(role, resource, action)
7. Request Handler     business logic via service layer only
8. Audit Logger        append-only write to audit_logs after response is
sent
9. Error Normalizer    strip stack traces; return RFC 7807 Problem Details
JSON
```

Required Security Response Headers

```
Content-Security-Policy: default-src 'self'; img-src 'self' data: https:;
script-src 'self'
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
X-Request-ID: <uuid>
```

PART 6 — SERVICE ABSTRACTION LAYER

All service code must implement provider-agnostic interfaces. No provider-specific types cross the interface boundary.

```
interface IAuthService {
  signIn(email: string, password: string): Promise<AuthSession>
```

```
  signOut(token: string): Promise<void>
  validateToken(token: string): Promise<UserClaims>
  refreshToken(refreshToken: string): Promise<AuthSession>
  sendPasswordReset(email: string): Promise<void>
  enableMFA(userId: string): Promise<MFASetup>
  verifyMFA(userId: string, code: string): Promise<boolean>
}

interface IStorageService {
  upload(bucket: string, path: string, file: Buffer, mime: string):
Promise<string>
  getSignedUrl(bucket: string, path: string, expiresIn: number):
Promise<string>
  delete(bucket: string, path: string): Promise<void>
}

interface INotificationService {
  sendInApp(userId: string, payload: NotificationPayload): Promise<void>
  sendEmail(to: string, template: EmailTemplate, data: object):
Promise<void>
  sendBulk(userIds: string[], payload: NotificationPayload): Promise<void>
  subscribe(channel: string, cb: (payload: object) => void): Unsubscribe
}

interface IComplaintService {
  create(data: CreateComplaintDTO, actorId: string): Promise<Complaint>
  getById(id: string, requesterId: string, role: string):
Promise<Complaint>
  list(filters: ComplaintFilters, requesterId: string, role: string):
Promise<Paginated<Complaint>>
  updateStatus(id: string, status: string, note: string, actorId: string):
Promise<Complaint>
  assign(id: string, assigneeId: string, actorId: string):
Promise<Complaint>
  addComment(id: string, body: string, internal: boolean, actorId: string):
Promise<Comment>
}

// Provider swap — change one env var:
const authService: IAuthService =
  process.env.PROVIDER === 'azure' ? new AzureAuthService() : new
SupabaseAuthService()
```

File Locations

```
src/lib/services/
  interfaces/     IAuthService.ts  IStorageService.ts
INotificationService.ts
                  IComplaintService.ts  IFinanceService.ts
IFacilityService.ts
                  IVisitorService.ts  IFeatureFlagService.ts
```

```
IPermissionService.ts
  providers/
    supabase/     SupabaseAuthService.ts  SupabaseStorageService.ts
                  SupabaseRealtimeService.ts  SupabaseDB.ts
    azure/        AzureAuthService.ts (stub)  AzureStorageService.ts (stub)
                  AzureSignalRService.ts (stub)
  index.ts        provider factory (reads PROVIDER env, exports instances)
  FeatureFlagService.ts
  PermissionService.ts
src/lib/middleware/
  rateLimiter.ts  jwtValidator.ts  featureFlagGuard.ts
  auditLogger.ts  securityHeaders.ts  errorNormalizer.ts
src/lib/utils/
  encryption.ts   AES-256 helpers for PII fields
  sanitize.ts     server-side DOMPurify wrapper
  pii.ts          strip PII from audit log old_values / new_values
  signedUrl.ts    generate + verify time-limited storage URLs
```

PART 7 — DATABASE SCHEMA (Fully Normalized PostgreSQL)

Foundation Tables

```
-- Multi-tenant root — one row per society
societies (
  id               uuid PK DEFAULT gen_random_uuid(),
  name             text NOT NULL,
  registration_no text UNIQUE,          -- TS MACS registration number
  address          text,
  city             text,
  state            text,
  pincode          text,
  total_units      int,
  total_area_acres numeric(5,2),
  gstin            text,                -- GST Registration Number
  pan              text,                -- PAN for TDS deduction purposes
  created_at       timestamptz DEFAULT now()
)

units (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid REFERENCES societies(id),
  unit_number      text NOT NULL,       -- "A-101"
  block            text,
  floor            int,
  area_sqft        numeric(8,2),
  unit_type        text,                -- "2BHK", "3BHK"
  is_vacant        boolean DEFAULT false,
  UNIQUE(society_id, unit_number)
)
```

```
profiles (
  id               uuid PK REFERENCES auth.users(id),
  society_id       uuid REFERENCES societies(id),
  full_name        text NOT NULL,
  unit_id          uuid REFERENCES units(id),
  phone_encrypted text,                  -- AES-256 encrypted
  residency_type   text CHECK (residency_type IN ('owner', 'tenant')),
  family_members   jsonb,                -- [{name, relation, phone_hash}]
  move_in_date     date,
  move_out_date    date,
  avatar_storage_key text,               -- storage bucket path, NOT public
URL
  is_active        boolean DEFAULT true,
  consent_version int,                   -- version of privacy policy
accepted
  consent_at       timestamptz,
  created_at       timestamptz DEFAULT now(),
  updated_at       timestamptz DEFAULT now()
)

user_roles (
  user_id          uuid PK REFERENCES auth.users(id),
  role             text NOT NULL CHECK (role IN
('member','executive','admin','security_guard','vendor')),
  society_id       uuid REFERENCES societies(id),
  granted_by       uuid REFERENCES auth.users(id),
  granted_at       timestamptz DEFAULT now(),
  expires_at       timestamptz           -- executive term expiry date
)

-- APPEND-ONLY. No UPDATE or DELETE RLS policies exist on this table.
audit_logs (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  user_id          uuid,
  action           text NOT NULL,        -- CREATE, UPDATE, DELETE, LOGIN,
LOGOUT,
                                         -- EXPORT, ROLE_CHANGE, PAYMENT,
DATA_ERASURE
  resource_type    text,
  resource_id      text,
  old_values       jsonb,                -- PII stripped before storage by
pii.ts
  new_values       jsonb,                -- PII stripped before storage by
pii.ts
  ip_hash          text,                 -- SHA-256(ip + daily_salt) — NOT
raw IP (DPDPA)
  user_agent_hash text,
  session_id       text,
  created_at       timestamptz DEFAULT now()
)

feature_flags (
  id               uuid PK DEFAULT gen_random_uuid(),
```

```
  society_id      uuid REFERENCES societies(id),
  module_key      text NOT NULL,
  feature_key     text NOT NULL,
  is_enabled      boolean DEFAULT true,
  allowed_roles   text[],
  config_json     jsonb,
  updated_by      uuid,
  updated_at      timestamptz DEFAULT now(),
  UNIQUE(society_id, module_key, feature_key)
)

module_configurations (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  module_key      text UNIQUE,
  display_name    text,
  is_active       boolean DEFAULT true,
  display_order   int,
  icon            text,
  updated_at      timestamptz DEFAULT now()
)
```

Complaints Module

```
complaint_sla_config (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  category        text,
  priority        text,
  sla_hours       int    -- Critical=4, High=24, Medium=48, Low=96
)

complaints (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  ticket_number   text UNIQUE,          -- UTA-2025-0001 (auto-generated
trigger)
  title           text NOT NULL,
  description     text,
  category        text NOT NULL,        -- Plumbing, Electrical, Lift,
Security,
                                        -- Housekeeping, Parking,
Water_Supply,
                                        -- Maintenance, Common_Area,
Pest_Control,
                                        -- Internet_Cable, Generator,
Garden, Other
  priority        text DEFAULT 'Medium' CHECK (priority IN
('Low','Medium','High','Critical')),
  status          text DEFAULT 'Open'   CHECK (status IN
('Open','Assigned','In_Progress',
```

```
'Waiting_for_User','Resolved','Closed','Reopened')),
  raised_by       uuid REFERENCES auth.users(id),
  assigned_to     uuid REFERENCES auth.users(id),
  unit_id         uuid REFERENCES units(id),
  sla_hours       int,
  sla_deadline    timestamptz,
  resolved_at     timestamptz,
  closed_at       timestamptz,
  reopen_count    int DEFAULT 0,
  created_at      timestamptz DEFAULT now(),
  updated_at      timestamptz DEFAULT now()
)

-- NO UPDATE RLS policies — comments are immutable once posted
complaint_comments (
  id              uuid PK DEFAULT gen_random_uuid(),
  complaint_id    uuid REFERENCES complaints(id),
  user_id         uuid REFERENCES auth.users(id),
  comment         text NOT NULL,
  is_internal     boolean DEFAULT false,
  created_at      timestamptz DEFAULT now()
)

complaint_attachments (
  id              uuid PK DEFAULT gen_random_uuid(),
  complaint_id    uuid REFERENCES complaints(id),
  storage_key     text NOT NULL,        -- bucket/path, NOT a public URL
  file_name       text,
  mime_type       text,
  file_size_bytes int,
  uploaded_by     uuid,
  created_at      timestamptz DEFAULT now()
)

-- Append-only status change history
complaint_status_history (
  id              uuid PK DEFAULT gen_random_uuid(),
  complaint_id    uuid REFERENCES complaints(id),
  old_status      text,
  new_status      text NOT NULL,
  note            text,
  changed_by      uuid,
  changed_at      timestamptz DEFAULT now()
)
```

Finance Module

```
billing_periods (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
```

```
  name            text,                  -- "Q1 FY2025-26"
  start_date      date,
  end_date        date,
  due_date        date,
  base_amount     numeric(10,2),
  is_active       boolean DEFAULT true
)

maintenance_dues (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  unit_id         uuid REFERENCES units(id),
  user_id         uuid REFERENCES auth.users(id),
  billing_period_id uuid REFERENCES billing_periods(id),
  base_amount     numeric(10,2),
  penalty_amount  numeric(10,2) DEFAULT 0,
  gst_amount      numeric(10,2) DEFAULT 0,
  total_amount    numeric(10,2) GENERATED ALWAYS AS (base_amount +
penalty_amount + gst_amount) STORED,
  status          text DEFAULT 'pending' CHECK (status IN
                  ('pending','partially_paid','paid','overdue','waived')),
  due_date        date,
  paid_at         timestamptz,
  created_at      timestamptz DEFAULT now(),
  updated_at      timestamptz DEFAULT now()
)

-- IMMUTABLE — no UPDATE or DELETE RLS policies
payments (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  dues_id         uuid REFERENCES maintenance_dues(id),
  user_id         uuid,
  amount          numeric(10,2) NOT NULL,
  payment_mode    text CHECK (payment_mode IN
('cash','cheque','upi','neft','rtgs','online')),
  transaction_ref text,
  receipt_number  text UNIQUE,           -- UTA-RCP-2025-0001 (auto-
generated trigger)
  receipt_storage_key text,
  gst_invoice_no  text,
  tds_deducted    numeric(10,2) DEFAULT 0,
  recorded_by     uuid,                  -- executive who recorded
cash/cheque payment
  paid_at         timestamptz NOT NULL,
  created_at      timestamptz DEFAULT now()
)

expense_categories (
  id, society_id, name text,
  gst_applicable boolean DEFAULT false,
  tds_applicable boolean DEFAULT false
)
```

```
expenses (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  category_id      uuid REFERENCES expense_categories(id),
  vendor_id        uuid REFERENCES vendors(id),
  description      text,
  amount           numeric(10,2),
  gst_amount       numeric(10,2) DEFAULT 0,
  tds_deducted     numeric(10,2) DEFAULT 0,
  net_payable      numeric(10,2) GENERATED ALWAYS AS (amount + gst_amount -
tds_deducted) STORED,
  bill_number      text,
  bill_date        date,
  payment_date     date,
  approved_by      uuid,
  receipt_storage_key text,
  created_at       timestamptz DEFAULT now(),
  created_by       uuid
)
```

Visitor & Security Module

```
visitor_pre_approvals (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  host_unit_id     uuid REFERENCES units(id),
  host_user_id     uuid REFERENCES auth.users(id),
  visitor_name     text NOT NULL,
  visitor_phone_hash text,              -- SHA-256 hash, not raw phone
  purpose          text,
  expected_date    date,
  expected_time_from timestamptz,
  expected_time_to   timestamptz,
  qr_token         text UNIQUE,          -- signed JWT with expiry
  otp_code_hash    text,
  status           text DEFAULT 'pending' CHECK (status IN
                   ('pending','approved','used','expired','cancelled')),
  created_at       timestamptz DEFAULT now(),
  expires_at       timestamptz
)

visitor_logs (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  pre_approval_id uuid REFERENCES visitor_pre_approvals(id),
  visitor_name     text,
  visitor_phone_hash text,
  host_unit_id     uuid REFERENCES units(id),
  entry_type       text CHECK (entry_type IN

('pre_approved','walk_in','delivery','service','vendor')),
```

```
  entry_time      timestamptz NOT NULL,
  exit_time       timestamptz,          -- only mutable field after
creation
  vehicle_number  text,
  logged_by       uuid REFERENCES auth.users(id),
  photo_storage_key text,               -- NOT a public URL
  created_at      timestamptz DEFAULT now()
)

delivery_logs (
  id, society_id, unit_id, courier_company, tracking_number text,
  received_at, collected_at timestamptz,
  collected_by, logged_by uuid,
  photo_storage_key text
)

staff_attendance (
  id, society_id, staff_id uuid, staff_name text,
  staff_type text, check_in, check_out timestamptz,
  logged_by uuid, date date
)
```

Facility & Booking Module

```
facilities (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  name            text NOT NULL,
  description     text,
  capacity        int,
  amenities       text[],
  images          text[],               -- storage keys
  booking_fee     numeric(10,2) DEFAULT 0,
  deposit_amount  numeric(10,2) DEFAULT 0,
  is_active       boolean DEFAULT true,
  advance_booking_days  int DEFAULT 30,
  cancellation_hours_free int DEFAULT 24
)

facility_slots (
  id, facility_id uuid, day_of_week int[],
  start_time time, end_time time, max_bookings int DEFAULT 1
)

facility_bookings (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  facility_id     uuid REFERENCES facilities(id),
  user_id         uuid,
  unit_id         uuid,
  booking_date    date,
```

```
  start_time      timestamptz,
  end_time        timestamptz,
  attendees_count int,
  purpose         text,
  status          text DEFAULT 'pending' CHECK (status IN

('pending','confirmed','in_use','completed','cancelled','no_show')),
  fee_charged     numeric(10,2),
  deposit_paid    numeric(10,2),
  deposit_refunded boolean DEFAULT false,
  cancelled_at    timestamptz,
  cancellation_reason text,
  created_at      timestamptz DEFAULT now()
)
```

Polls & Governance

```
polls (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  title           text NOT NULL,
  description     text,
  poll_type       text CHECK (poll_type IN
('single_choice','multiple_choice','yes_no','rating')),
  scope           text DEFAULT 'all_members' CHECK (scope IN
('all_members','owners_only','block_specific')),
  target_blocks   text[],
  is_anonymous    boolean DEFAULT false,
  one_vote_per_unit boolean DEFAULT false,
  starts_at       timestamptz,
  ends_at         timestamptz,
  is_published    boolean DEFAULT false,
  result_visibility text DEFAULT 'after_close' CHECK (result_visibility IN
                  ('after_vote','after_close','executive_only')),
  created_by      uuid,
  created_at      timestamptz DEFAULT now()
)

-- NO vote_count cache column — prevents drift from concurrent writes
-- Always use COUNT(poll_votes) in queries
poll_options (
  id              uuid PK DEFAULT gen_random_uuid(),
  poll_id         uuid REFERENCES polls(id),
  option_text     text NOT NULL,
  order_index     int
)

poll_votes (
  id              uuid PK DEFAULT gen_random_uuid(),
  poll_id         uuid REFERENCES polls(id),
  option_id       uuid REFERENCES poll_options(id),
```

```
  user_id         uuid NOT NULL,        -- always stored; stripped from API
response if poll.is_anonymous
  unit_id         uuid,                 -- for one_vote_per_unit
enforcement
  voted_at        timestamptz DEFAULT now(),
  UNIQUE(poll_id, user_id)
)
```

Events

```
events (
  id              uuid PK DEFAULT gen_random_uuid(),
  society_id      uuid,
  title           text NOT NULL,
  description     text,
  category        text,
  starts_at       timestamptz,
  ends_at         timestamptz,
  location        text,
  capacity        int,
  waitlist_capacity int DEFAULT 0,
  registration_deadline timestamptz,
  is_paid         boolean DEFAULT false,
  ticket_price    numeric(10,2) DEFAULT 0,
  gst_on_ticket   boolean DEFAULT false,
  is_published    boolean DEFAULT false,
  banner_storage_key text,
  created_by      uuid,
  created_at      timestamptz DEFAULT now()
)

event_registrations (
  id              uuid PK DEFAULT gen_random_uuid(),
  event_id        uuid REFERENCES events(id),
  user_id         uuid,
  unit_id         uuid,
  attendees_count int DEFAULT 1,
  status          text DEFAULT 'registered' CHECK (status IN

('registered','waitlisted','attended','cancelled','no_show')),
  payment_id      uuid,                 -- nullable for free events
  qr_token        text UNIQUE,          -- for QR check-in
  checked_in_at   timestamptz,
  registered_at   timestamptz DEFAULT now(),
  UNIQUE(event_id, user_id)
)
```

Communication, Notifications, Vendors, Staff, Documents, Assets, Community

```
-- Notices
notices (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  title            text NOT NULL,
  body             text,                 -- sanitized HTML; DOMPurify
applied server-side before INSERT
  category         text CHECK (category IN
('Urgent','General','Maintenance','Financial','Events','Governance')),
  target_audience text DEFAULT 'all' CHECK (target_audience IN
('all','owners','tenants','block_specific')),
  target_blocks    text[],
  is_pinned        boolean DEFAULT false,
  is_published     boolean DEFAULT false,
  requires_acknowledgement boolean DEFAULT false,
  published_at     timestamptz,
  expires_at       timestamptz,
  attachment_storage_key text,
  created_by       uuid,
  created_at       timestamptz DEFAULT now(),
  updated_at       timestamptz DEFAULT now()
)

notice_acknowledgements (
  notice_id        uuid REFERENCES notices(id),
  user_id          uuid,
  acknowledged_at timestamptz DEFAULT now(),
  PRIMARY KEY (notice_id, user_id)
)

-- Notifications
notifications (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  user_id          uuid REFERENCES auth.users(id),
  title            text,
  body             text,
  type             text,                 -- complaint, event, notice, poll,
payment,
                                         -- visitor, facility, system,
security_alert
  reference_table text,
  reference_id     uuid,
  channel          text,                 -- in_app, email, sms, whatsapp,
push
  status           text DEFAULT 'pending',
  is_read          boolean DEFAULT false,
  read_at          timestamptz,
  sent_at          timestamptz,
  created_at       timestamptz DEFAULT now(),
  expires_at       timestamptz
)
```

```
notification_preferences (
  user_id          uuid PK REFERENCES auth.users(id),
  complaints       boolean DEFAULT true,
  notices          boolean DEFAULT true,
  events           boolean DEFAULT true,
  polls            boolean DEFAULT true,
  payments         boolean DEFAULT true,
  visitor_alerts   boolean DEFAULT true,
  email_enabled    boolean DEFAULT true,
  sms_enabled      boolean DEFAULT false,   -- requires TRAI DLT explicit
opt-in
  push_enabled     boolean DEFAULT false,
  quiet_hours_start time,
  quiet_hours_end   time
)

-- Vendors
vendors (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  name             text NOT NULL,
  category         text,
  contact_person   text,
  phone            text,
  email            text,
  gstin            text,
  pan              text,                    -- mandatory for TDS deduction
  bank_account_encrypted text,
  bank_ifsc        text,
  contract_start   date,
  contract_end     date,
  is_active        boolean DEFAULT true,
  created_at       timestamptz DEFAULT now()
)

work_orders (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  vendor_id        uuid REFERENCES vendors(id),
  complaint_id     uuid REFERENCES complaints(id),
  title            text,
  description      text,
  status           text DEFAULT 'draft' CHECK (status IN

('draft','issued','in_progress','completed','disputed','closed')),
  issued_at        timestamptz,
  deadline         timestamptz,
  completed_at     timestamptz,
  quoted_amount    numeric(10,2),
  final_amount     numeric(10,2),
  created_by       uuid
)
```

```
-- Staff
staff_members (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  name             text NOT NULL,
  role             text,
  phone            text,
  id_proof_type    text,
  id_proof_encrypted text,             -- AES-256
  joining_date     date,
  is_active        boolean DEFAULT true
)

-- Documents (with versioning)
documents (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  title            text NOT NULL,
  description      text,
  category         text CHECK (category IN
('Bylaws','Minutes','Financial','Legal','Circulars','Forms','Other')),
  storage_key      text NOT NULL,        -- signed URL reference only, never
a public path
  file_name        text,
  mime_type        text,
  file_size_bytes int,
  version          int DEFAULT 1,
  parent_id        uuid REFERENCES documents(id),  -- versioning chain
  is_public        boolean DEFAULT false,
  requires_role    text CHECK (requires_role IN
('member','executive','admin')),
  created_by       uuid,
  created_at       timestamptz DEFAULT now(),
  updated_at       timestamptz DEFAULT now()
)

-- Infrastructure Assets
infrastructure_assets (
  id               uuid PK DEFAULT gen_random_uuid(),
  society_id       uuid,
  name             text NOT NULL,
  category         text,                 -- Lift, Generator, Pump, CCTV,
Fire_Safety, Gate, Electrical, Other
  make             text,
  model            text,
  serial_number    text,
  installation_date date,
  warranty_expiry  date,
  next_service_date date,
  amc_vendor_id    uuid REFERENCES vendors(id),
  amc_start        date,
  amc_end          date,
  amc_amount       numeric(10,2)
)
```

```
asset_maintenance_logs (
  id                uuid PK DEFAULT gen_random_uuid(),
  asset_id          uuid REFERENCES infrastructure_assets(id),
  service_date      date,
  service_type      text,
  description       text,
  cost              numeric(10,2),
  vendor_id         uuid,
  invoice_storage_key text,
  next_service_date date,
  performed_by      text,
  created_at        timestamptz DEFAULT now()
)

-- Community Posts
community_posts (
  id                uuid PK DEFAULT gen_random_uuid(),
  society_id        uuid,
  author_id         uuid,
  unit_id           uuid,
  category          text,                  -- General, Help, Lost_Found,
Recommendation, Alert
  title             text,
  body              text,                  -- sanitized HTML
  images            text[],                -- storage keys
  is_pinned         boolean DEFAULT false,
  is_published      boolean DEFAULT true,
  is_moderated      boolean DEFAULT false,
  moderated_by      uuid,
  moderation_note text,
  created_at        timestamptz DEFAULT now(),
  updated_at        timestamptz DEFAULT now()
)

post_comments (
  id, post_id, author_id, body text,
  parent_id uuid REFERENCES post_comments(id),
  is_hidden boolean DEFAULT false,
  created_at timestamptz DEFAULT now()
)

post_reactions (
  post_id           uuid,
  user_id           uuid,
  reaction_type     text CHECK (reaction_type IN ('like','helpful')),
  PRIMARY KEY (post_id, user_id)
)

marketplace_listings (
  id                uuid PK DEFAULT gen_random_uuid(),
  society_id        uuid,
  seller_id         uuid,
  unit_id           uuid,
```

```
  category        text,
  title           text,
  description     text,
  price           numeric(10,2),
  images          text[],               -- storage keys
  status          text DEFAULT 'active' CHECK (status IN
('active','sold','expired','removed')),
  contact_preference text CHECK (contact_preference IN ('in_app','phone')),
  expires_at      timestamptz,
  created_at      timestamptz DEFAULT now()
)
```

PART 8 — STATE MACHINES

Complaint Lifecycle

```
                    ┌──────────┐
   Raise            │  Open    │
──────────────────► └──────────┘
                         │
                         ▼ Assign (Exec/Admin)
                    ┌──────────┐
                    │ Assigned │
                    └──────────┘
                         │
                         ▼ Work begins
                    ┌──────────────┐◄──────────────────────────┐
                    │ In Progress  │                           │
                    └──────────────┘                           │
                         │                          Reopen (within 7d)
          ┌──────────────┼──────────────┐                     │
          │              │              │                     │
      Need Info       Resolve      Escalate                    │
          │              │              │                     │
   ┌──────▼──────┐  ┌────▼────────┐  ┌──▼──────────────┐      │
   │ Waiting     │  │ Resolved    │  │ Critical        │      │
   │ for User    │  └─────────────┘  │ Escalated       │      │
   └─────────────┘        │          └─────────────────┘      │
         │                │                                   │
         │                ▼ Auto-close after 72h              │
         │ User responds  │                                   │
         └──────────────► │                                   │
                    ┌──────▼──────┐                           │
                    │ Closed      │──────────────────────────┘
                    └─────────────┘
```

Payment State Machine

```
Dues Created
  → Pending          awaiting payment
  → Processing       payment gateway initiated
```

```
  → Paid              IMMUTABLE — no reverse transition permitted
  → Partially Paid    partial receipt recorded
  → Overdue           due_date passed → automatic penalty trigger
  → Waived            requires dual approval: executive + admin
```

Facility Booking State Machine

```
Request Created
  → Pending        awaiting capacity check and fee (if applicable)
  → Confirmed      capacity available, fee paid
  → Waitlisted     capacity full; auto-promoted when cancellation occurs
  → In Use         booking start time reached
  → Completed      end time passed; deposit refund initiated
  → Cancelled      user cancels; refund if within cancellation window
  → No Show        30 minutes past start with no check-in; deposit
forfeited
```

PART 9 — SECURITY DESIGN

Authentication Controls

- Access tokens: 15-minute expiry; refresh tokens: 7-day, single-use with automatic rotation
- Failed login policy: 5 attempts → 15-minute lockout → account alert email sent
- MFA: **mandatory** for Admin; **strongly recommended** for Executive roles
- Session binding: device fingerprint (user-agent hash); anomaly alert on new device or location

Authorization — Defense in Depth

```
Layer 1: API Gateway     JWT signature validation + role extraction from
token claims
Layer 2: Service Layer   PermissionService.authorize(role, resource,
action) before any DB access
Layer 3: Data Layer      RLS policies (provider-specific but defined via
interface)
Layer 4: Response        PII fields stripped based on requester role before
JSON response is sent
```

Fixed RLS Policies (correcting v1 security gaps)

```
-- FIX 1: Add WITH CHECK to complaints_update to prevent field tampering
CREATE POLICY complaints_update ON complaints
  FOR UPDATE
  USING (get_user_role(auth.uid()) IN ('executive', 'admin'))
  WITH CHECK (
    raised_by = (SELECT raised_by FROM complaints WHERE id = complaints.id)
```

```sql
    AND get_user_role(auth.uid()) IN ('executive', 'admin')
  );

-- FIX 2: Audit logs — insert-only; no UPDATE or DELETE policies = Supabase
default deny
CREATE POLICY audit_insert ON audit_logs
  FOR INSERT WITH CHECK (user_id = auth.uid());
CREATE POLICY audit_admin_read ON audit_logs
  FOR SELECT USING (get_user_role(auth.uid()) = 'admin');

-- FIX 3: Payments — insert-only (financial immutability)
CREATE POLICY payments_insert ON payments
  FOR INSERT WITH CHECK (auth.uid() IS NOT NULL);
-- No UPDATE or DELETE policies — payments cannot be modified after
creation

-- FIX 4: Poll votes — user_id is NOT NULL always
-- If poll.is_anonymous = true, the API layer strips user_id from response
JSON
-- Never store NULL user_id; anonymity is a presentation concern, not a DB
concern

-- FIX 5: Complaint comments — insert-only (immutable discussion thread)
CREATE POLICY complaint_comments_insert ON complaint_comments
  FOR INSERT WITH CHECK (user_id = auth.uid());
-- No UPDATE or DELETE policies
```

Input Validation & Sanitization

- Rich text (notices body, community posts): `DOMPurify.sanitize(body)` called **server-side** in service layer before every INSERT and UPDATE
- File uploads: MIME type inspected via magic bytes (not just extension); max 10MB enforced at API middleware
- Phone numbers: validated to E.164 format, then AES-256 encrypted before DB write
- Unit numbers: validated against `units` table on profile creation — no free-text accepted

Data Encryption

- PII fields (phone, staff ID proofs, vendor bank accounts): AES-256 at application layer before DB
- Encryption keys: stored in Vercel environment variables or Azure Key Vault — never in DB or source code
- Storage files: served exclusively via signed URLs with 10-minute expiry; no public CDN paths stored in DB
- IP addresses: `SHA-256(ip_address + rotating_daily_salt)` stored — raw IPs never persisted (DPDPA Article 3)

PART 10 — PRIVACY & COMPLIANCE (INDIA)

DPDPA 2023 (Digital Personal Data Protection Act)

Requirement	Implementation
Explicit consent	`profiles.consent_version` + `profiles.consent_at`; re-consent popup on policy version change
Data localization	Supabase project = `ap-south-1` (Mumbai); Azure migration target = Central India
Right to erasure	`DELETE /api/v1/members/:id/personal-data` — anonymizes PII columns; retains pseudonymous non-personal records
Data minimization	Only functionally necessary fields collected; no behavioral analytics or tracking pixels
Privacy notice	Displayed at registration; re-displayed on every policy version increment
Breach notification	72-hour documented procedure to CERT-In per IT (Amendment) Rules 2022

IT Act 2000 & CERT-In Rules 2022

- Reasonable Security Practices documented: rate limiting, MFA, AES-256, RLS, access control
- Raw IP never stored — SHA-256 hash only; law enforcement requests handled via legal process
- Incident response plan: Admin → CERT-In (72h) → Exec → member notification (24h)

Financial Compliance

Requirement	Implementation
GST	`societies.gstin` stored; invoices auto-generated for facility booking fees, paid event tickets; GST breakdowns on all receipts
TDS	`vendors.pan` mandatory; TDS computed at IT Act Section 194C rates on work orders > ₹30K/year; Form 16A generation in Phase 5
TS MACS Act 1995	AGM minutes, annual accounts in Documents module with exec→admin approval workflow; financial records immutable
Cooperative audit	Expense approval (exec proposes → admin approves); P&L + Balance Sheet generation; immutable payments table

TRAI DLT (Distributed Ledger Technology)

- Feature flags `sms_trai_dlt` and `whatsapp_trai_dlt` are **disabled by default**
- Admin UI requires confirmation of TRAI entity registration + template registration ID before enabling
- Explicit member opt-in with TRAI-compliant consent stored in `notification_preferences`
- Bulk messaging without DLT registration is a criminal offence under TRAI regulations

---

PART 11 — MIGRATION PLAN: SUPABASE → AZURE

Guiding constraint: Zero frontend code changes required. Only provider implementations are swapped.

Migration Phases

```
Phase A — Preparation (while live on Supabase)
  1. Confirm 100% of UI calls route through /api/v1/* — zero direct
Supabase SDK from frontend
  2. All IService interfaces finalized, tested, and documented with API
contracts
  3. DB schema exportable as pure standard PostgreSQL (zero Supabase-
specific syntax)
  4. Integration test suite covers all /api/v1/* endpoints provider-
agnostically
  5. All RLS logic re-expressible as Azure row-level security predicates

Phase B — Azure Provisioning
  1. Azure Database for PostgreSQL Flexible Server — Central India region
(DPDPA localization)
  2. Azure Blob Storage — 7 containers matching current Supabase storage
buckets
  3. Microsoft Entra External ID — authentication tenant
  4. Azure App Service / Azure Functions — service layer hosting
  5. Azure SignalR Service — replaces Supabase Realtime
  6. Azure Key Vault — encryption keys + application secrets

Phase C — Data Migration
  1. pg_dump Supabase → pg_restore to Azure PostgreSQL
  2. Automated script: copy all objects from Supabase Storage → Azure Blob
  3. IP hashes already safe (no raw IPs to scrub)
  4. Auth migration: export user table → Entra import; users receive
password-reset email on first login

Phase D — Cutover (Zero-Downtime Blue-Green)
  1. Deploy Azure provider implementations in staging environment
  2. Set PROVIDER=azure in Vercel environment variables
  3. Run full smoke test suite against all /api/v1/* endpoints
  4. Update DNS CNAME records; monitor for 48 hours
  5. Rollback path: set PROVIDER=supabase, redeploy (< 5 minutes)

Phase E — Supabase Decommission
  1. Keep Supabase instance read-only for 30 days (audit and rollback
period)
  2. Terminate Supabase project after 30-day window
  3. Update documentation and CLAUDE.md
```

PART 12 — DEPLOYMENT STRATEGY

Current and Target Topology

```
Domain                  Current                     Post-Migration
_______________________ ___________________________
```

```
──────────────────────────────────
utamacs.org             GitHub Pages (static)      GitHub Pages (unchanged)
portal.utamacs.org      Vercel (Astro SSR)          Vercel OR Azure App
Service
/api/v1/*               Vercel Functions            Azure Functions
Database                Supabase PostgreSQL         Azure Database for
PostgreSQL
Authentication          Supabase Auth               Azure Entra External ID
Storage                 Supabase Storage            Azure Blob Storage
Realtime                Supabase Realtime           Azure SignalR Service
Email                   Resend via Edge Function    Azure Communication
Services
```

Required Environment Variables

```
# Provider selector — single env var to trigger migration
PROVIDER=supabase                       # or 'azure'

# Common to all providers
API_BASE_URL=https://portal.utamacs.org/api/v1
ENCRYPTION_KEY=...                      # AES-256 key; stored in Key Vault
only — never in repo

# Supabase (active when PROVIDER=supabase)
SUPABASE_URL=https://xxx.supabase.co
SUPABASE_ANON_KEY=...                   # safe for client-side bundle
SUPABASE_SERVICE_ROLE_KEY=...           # server-side ONLY — never exposed
to browser

# Azure (active when PROVIDER=azure)
AZURE_TENANT_ID=...
AZURE_CLIENT_ID=...
AZURE_DB_URL=...
AZURE_STORAGE_CONNECTION=...
AZURE_SIGNALR_CONNECTION=...
AZURE_KEY_VAULT_URI=...
```

PART 13 — SCALABILITY STRATEGY

Concern	Supabase Phase	Azure Migration
API horizontal scale	Vercel serverless auto-scale	Azure Functions Premium Plan
DB connection pooling	PgBouncer (built into Supabase)	Azure PgSQL connection pooler
Read scaling	Supabase read replica ($25/mo add-on)	Azure read replicas

Concern	Supabase Phase	Azure Migration
Response caching	Vercel Edge Cache (30s TTL for lists)	Azure CDN + Azure Cache for Redis
Feature flag cache	In-memory per instance, 60s TTL	Azure Redis Cache, 60s TTL
Static assets	Vercel Edge Network	Azure CDN
Multi-tenancy	`society_id` FK on all tables from day one	Same schema; tenant isolation by row
Realtime push	Supabase Realtime channels	Azure SignalR Service

---

PART 14 — REVISED IMPLEMENTATION ROADMAP

Phase 1 — Foundation + Feature Flags (Weeks 1–3)

1. Run all 14 DB migrations (`001` through `014`)
2. Implement all `IService` interfaces + Supabase provider classes
3. API gateway with full 9-step middleware stack
4. Feature flag service + admin configuration UI
5. Auth: login, logout, refresh, password reset; MFA stub wired for admin
6. Portal shell: `PortalLayout.astro` + role-adaptive sidebar (shows only enabled modules)
7. Verification checklist: login → correct dashboard → logout → unauthenticated redirect; toggle feature flag → UI reflects change immediately without redeploy

Phase 2 — Member Core (Weeks 4–7)

1. Profile management (PII AES-256 encrypted, consent version tracked)
2. Complaints: full lifecycle Open → Closed with SLA countdown indicators
3. Notices: acknowledgement tracking, targeted audience, expiry
4. Events: RSVP + capacity enforcement + waitlist
5. Notification system: in-app realtime + email via Resend
6. Member dashboard KPI cards wired to live data

Phase 3 — Executive Tools (Weeks 8–11)

1. Executive dashboard: recharts complaint aging donut, dues bar chart, engagement trends
2. Content management: create/edit/publish notices, events, polls
3. Complaint management: all tickets, assign to self/others, internal comments, SLA breach alerts
4. Finance: billing periods, dues creation, payment recording, GST invoice generation
5. Document management: version control, access control, signed URL delivery

Phase 4 — Visitor & Facility (Weeks 12–15)

1. Visitor pre-approval: QR code + OTP flow
2. Security guard UI: entry/exit logging, photo upload
3. Delivery tracking: package log, OTP collection confirmation
4. Facility booking: slot availability, capacity, deposit, cancellation policy

5. Parking allocation module

Phase 5 — Admin & Compliance (Weeks 16–18)

1. Admin dashboard: all-module KPIs + system health endpoint
2. User/role management with executive term expiry enforcement
3. Audit log viewer: filterable, DPDPA-compliant export (hashed IPs in output)
4. TDS tracking: vendor PAN management, threshold monitoring, Form 16A generation
5. AGM document workflow: minutes upload, resolution approval, financial statement sign-off
6. Right-to-erasure endpoint: `DELETE /api/v1/members/:id/personal-data`
7. Consent version management UI

Phase 6 — Community & Assets (Weeks 19–21)

1. Community posts: threaded comments, reactions, moderation queue, pin
2. Marketplace listings: category, photos, status lifecycle
3. Infrastructure asset register: AMC alerts, maintenance log, warranty tracking
4. Staff attendance tracking + work order management

Phase 7 — Advanced + Azure Migration (Weeks 22+)

1. Automation engine: auto-assign complaints, SLA escalation, billing triggers, payment reminders
2. AI insights: complaint pattern analysis, predictive maintenance alerts
3. PWA manifest + service worker (offline notice reading on mobile)
4. WhatsApp/SMS notifications (enabled only after TRAI DLT registration confirmed)
5. Azure migration execution per Phase 11 plan (parallel run → cutover)
6. Annual security review: penetration test + DPDPA compliance audit

---

PART 15 — COMPLETE FILE STRUCTURE

```
utamacs-website/
├── src/
│   ├── lib/
│   │   ├── services/
│   │   │   ├── interfaces/
│   │   │   │   ├── IAuthService.ts
│   │   │   │   ├── IStorageService.ts
│   │   │   │   ├── INotificationService.ts
│   │   │   │   ├── IComplaintService.ts
│   │   │   │   ├── IFinanceService.ts
│   │   │   │   ├── IFacilityService.ts
│   │   │   │   ├── IVisitorService.ts
│   │   │   │   ├── IFeatureFlagService.ts
│   │   │   │   └── IPermissionService.ts
│   │   │   ├── providers/
│   │   │   │   ├── supabase/
│   │   │   │   │   ├── SupabaseAuthService.ts
│   │   │   │   │   ├── SupabaseStorageService.ts
│   │   │   │   │   ├── SupabaseRealtimeService.ts
```

```
│   │   │   │   │   └── SupabaseDB.ts
│   │   │   │   └── azure/
│   │   │   │       ├── AzureAuthService.ts        (stub)
│   │   │   │       ├── AzureStorageService.ts     (stub)
│   │   │   │       └── AzureSignalRService.ts     (stub)
│   │   │   ├── index.ts                            provider factory
│   │   │   ├── FeatureFlagService.ts
│   │   │   └── PermissionService.ts
│   │   ├── middleware/
│   │   │   ├── rateLimiter.ts
│   │   │   ├── jwtValidator.ts
│   │   │   ├── featureFlagGuard.ts
│   │   │   ├── auditLogger.ts
│   │   │   ├── securityHeaders.ts
│   │   │   └── errorNormalizer.ts
│   │   └── utils/
│   │       ├── encryption.ts      AES-256 PII helpers
│   │       ├── sanitize.ts        server-side DOMPurify wrapper
│   │       ├── pii.ts             strip PII from audit log values
│   │       └── signedUrl.ts       generate + verify time-limited storage
URLs
│   ├── pages/
│   │   ├── api/v1/                API Gateway routes (Astro API endpoints)
│   │   │   ├── auth/
│   │   │   ├── members/
│   │   │   ├── complaints/
│   │   │   ├── finance/
│   │   │   ├── visitors/
│   │   │   ├── facilities/
│   │   │   ├── notices/
│   │   │   ├── events/
│   │   │   ├── polls/
│   │   │   └── admin/
│   │   └── portal/                SSR portal pages (prerender: false)
│   │       ├── index.astro
│   │       ├── profile.astro
│   │       ├── complaints/
│   │       ├── notices/
│   │       ├── events/
│   │       ├── polls/
│   │       ├── finance/
│   │       ├── facilities/
│   │       ├── visitors/
│   │       ├── community/
│   │       └── admin/
│   └── components/portal/          React islands (client:load)
│       ├── auth/
│       ├── shared/                 DataTable, StatusBadge, Pagination,
NotificationBell
│       ├── dashboard/              MemberDashboard, ExecutiveDashboard,
AdminDashboard
│       ├── complaints/
│       ├── notices/
│       ├── events/
```

```
│       ├── polls/
│       ├── finance/
│       ├── facilities/
│       ├── visitors/
│       ├── community/
│       ├── admin/
│       └── profile/
├── supabase/
│   └── migrations/
│       ├── 001_foundation.sql     societies, units, profiles, user_roles,
audit_logs
│       ├── 002_complaints.sql
│       ├── 003_finance.sql
│       ├── 004_visitors.sql
│       ├── 005_facilities.sql
│       ├── 006_polls_events.sql
│       ├── 007_communication.sql
│       ├── 008_vendors_staff.sql
│       ├── 009_community.sql
│       ├── 010_documents_assets.sql
│       ├── 011_feature_flags.sql
│       ├── 012_rls.sql            all RLS policies (including security
fixes)
│       ├── 013_functions.sql      get_user_role(), audit triggers, SLA
trigger,
│       │                          ticket_number generator, receipt_number
generator
│       └── 014_seed.sql           test society, 8 units, 5 test users,
sample data
├── astro.config.mjs               static, outDir: docs/ (GitHub Pages)
├── astro.portal.config.mjs        hybrid, @astrojs/vercel (portal)
├── vercel.json                    build command override to portal config
└── design/
    ├── ARCHITECTURE.md            v1 — superseded by this document
    └── new-architecture.md        this document (v2.0)
```

PART 16 — COST SUMMARY

Service	Plan	Monthly Cost
GitHub Pages	Free	$0
Vercel	Hobby (free tier)	$0
Supabase	Free dev tier (auto-pauses after 7 days inactive)	$0
Resend (email)	Free 3,000/month	$0
Development total		**$0/mo**
Supabase Pro	Production — removes auto-pause	$25/mo
Vercel Pro	If traffic exceeds free tier limits	$20/mo

Service	Plan	Monthly Cost
Production total		**$25–45/mo**
Azure (post-migration)	Flexible Server + Blob + Entra + SignalR	~$50–80/mo

---

Appendix A — Module Summary

#	Module	Phase	Feature Flag Key
1	Security, Access & Visitor Management	4	`visitor_mgmt`
2	Member & Community Management	2	`members`
3	Complaint & Service Management	2	`complaints`
4	Finance, Billing & Accounting	3	`finance`
5	Communication & Notices	2	`notices`
6	Polls & Governance	3	`polls`
7	Events & Engagement	2	`events`
8	Facility, Membership & Booking	4	`facility_booking`
9	Equipment & Asset Management	6	`asset_mgmt`
10	Infrastructure Asset Management	6	`asset_mgmt`
11	Parking & Vehicle Management	4	`parking`
12	Staff & Vendor Management	3	`vendors`
13	Delivery & Logistics	4	`visitor_mgmt`
14	Document Management	3	`documents`
15	Dashboard & Analytics	2–5	`analytics`
16	Notifications System	2	`notifications`
17	Community Marketplace	6	`community`
18	Compliance & Audit	5	`compliance`
19	Automation Engine	7	`automation`